

Firebase API Key Exposure Incident

Security Incident — Firebase Android API Key in Git History

Revision: 1 **Last modified:** 2026-06-29T13:05:00Z **Severity:** Medium (Firebase Android API key — restrictable, not a server secret) **Authority:** Constitution §11.4.10 (credentials must not leak) + §11.4.10.A (pre-store leak audit) **Status:** OPERATOR ACTION REQUIRED — rotation/restriction decision pending

What

The live Firebase **Android API key** for `com.catalogizer.androidtv` (project `catalogizer-7a3f1`) was committed in plaintext to `docs/CONTINUATION.md`.

- **Key:** `AIzaSyCZBC...aPRw` (redacted here; full value in `gitignored.env` + `~/api_keys.sh`)
- **Leak commit:** `4cbc1311` (“docs: CONTINUATION.md Rev 6 — full session state”), a PRIOR session
- **Published:** YES — `4cbc1311` is an ancestor of remote HEAD `06254f8d` on all 6 remotes (github ×2, gitlab ×2, gitflic, gitverse)
- **Same key** is the live key embedded in the (correctly `gitignored`) `google-services.json`, in active use by the shipped Android TV app.

Remediation taken (autonomous, safe, reversible)

1. Redacted the key from `docs/CONTINUATION.md` (local HEAD `985e47b9`, NOT yet pushed — clean).

2. Regenerated .html/.pdf exports key-free (verified 0 occurrences in all 3 formats).
3. §11.4.10.A history audit: key appears ONLY in docs/CONTINUATION.md across history (commits 4cbc1311 published + 985e47b9 local-redaction). Not in any source/config tracked file.
4. Documented here.

OPERATOR ACTION REQUIRED (cannot be done autonomously — §11.4.101)

The key is already published; redaction-going-forward cannot unpublish it. Choose:

- **[A] Restrict + keep (recommended for Firebase Android keys).** Firebase Android API keys are designed to be embedded in client apps and are NOT secret by Google's model. Lock the key in Google Cloud Console → APIs & Credentials → restrict to Android app (package com.catalogizer.androidtv + SHA-256 signing cert) + restrict to only the Firebase APIs used + enable App Check. This neutralizes the exposure without breaking the live app. No rotation, no history rewrite.
- **[B] Rotate.** Generate a new Android API key in Cloud Console, regenerate google-services.json, rebuild + redistribute the app, then delete the old key. Most thorough but breaks the live app until the new APK ships.
- **[C] History purge.** Rewrite history to remove 4cbc1311's key. Requires force-push — **FORBIDDEN by §11.4.113 absent explicit operator override.** Even if done, the key is already scraped-cacheable on public remotes, so [A] or [B] is still required.

Recommended: **[A]** (correct for this key class) + optionally [B] later if policy demands rotation.